[DOSSIER TECNICO & REGIA] [EU CRA 2024/2847]
[SUPPLY CHAIN DEFENSE]

aiutiamoci.cloud • Masterclass AI Pro 2026/2027

Destinatario: Stefano (Socio & Relatore Tecnico)
Track Formativa: Cybersecurity & AI Defense (Modulo 6)
Revisione: Edizione Ufficiale UE 2024/2847 (Novembre 2026)

VIBE CODING & CYBER RESILIENCE ACT (UE 2024/2847)

Dal Prototipo AI al Software Blindato & Conforme: Copione Video Teleprompter, Guida Operativa Software Supply Chain (SBOM CycloneDX 1.5) e Scadenze Normative (11 Settembre 2026 / 11 Dicembre 2027).

1. SCHEDA REGIA & LINEE GUIDA PER IL CONDUTTORE

10-12 MIN
DURATA TARGET VIDEO
Ritmo serrato, orientato alla soluzione tecnica. Nessun allungamento teorico.

PRAGMATICO
TONO DI VOCE
Zero allarmismo e zero clickbait. Approccio da ingegnere senior verso colleghi e PMI.

5 ATTI
STRUTTURA NARRATIVA
Mito smentito -> Le 2 Scadenze -> Il Vero Rischio -> Live Screencast -> Protocollo 24h.

[INDICAZIONI DI REGIA PER STEFANO]

OBIETTIVO DEL VIDEO: *Posizionarci come l'unico polo formativo in Italia che non insegna solo il "vibe coding" per fare demo giocattolo, ma insegna a trasformare il codice generato dall'AI in software commerciale vendibile alle aziende, conforme alla nuova legge europea CRA.*
SETUP VISIVO: *Alternanza tra Mezzo Busto frontale (apertura, concetti legali, chiusura) e Screencast ad alta definizione (ispezione file BUILD_INFO.json, SBOM CycloneDX e comando terminale del Radar).*
REGOLA CHIAVE: *Non fare mai terrorismo psicologico. Chi programma con l'AI non deve avere paura della legge: deve solo adottare i corretti strumenti di ingegneria della supply chain.*

2. MAPPA STRUTTURALE DEI 5 ATTI VIDEO

Atto / Minuto	Tema Principale	Messaggio Chiave per lo Spettatore	Inquadratura & Setup
Atto 1 (Min 00:00 - 02:15)	**Smontare il Falso Allarmismo:** "Il Vibe Coding finisce nel 2026?"	L'UE non vieta l'AI e non colpisce esperimenti o SaaS puri. Colpisce chi immette sul mercato prodotti con elementi digitali senza conoscere la propria supply chain.	Mezzo Busto Frontale + Sovrimpressione testo dinamico [VERITÀ vs BUFALA].
Atto 2 (Min 02:15 - 04:30)	**Le 2 Vere Scadenze del CRA:** 11 Settembre 2026 vs 11 Dicembre 2027	Nel 2026 scatta l'obbligo di notifica entro 24h a ENISA e CSIRT/ACN per vulnerabilità sfruttate. Nel 2027 scatta la piena marcatura CE del software.	Mezzo Busto + Grafica a tutta pagina Timeline CRA (24h -> 72h -> 14gg).
Atto 3 (Min 04:30 - 07:00)	**Il Tallone d'Achille del Vibe Coder:** La Software Supply Chain Open Source	Chiedere all'AI 40 pacchetti significa imbarcare 800 librerie transitive. La domanda da 1 milione: "Se esce una CVE critica domani, lo scopri in 24h?".	Mezzo Busto + Slide Comparativa [KO Vibe Coding Cieco] vs [OK Ingegneria AI].
Atto 4 (Min 07:00 - 09:45)	**Dimostrazione Live a Schermo:** BUILD_INFO, SBOM CycloneDX & Radar	Tre passi pratici in 3 minuti: il file di identità build, la distinta base standard CycloneDX 1.5 e il comando CLI che interroga tutti i 19 progetti in 50ms.	Screencast Schermo Intero con terminale e VS Code (font grande 16pt, tema scuro).
Atto 5 (Min 09:45 - 11:30)	**Il Protocollo Operativo 24h/72h:** Risposta CSIRT & Call to Action	Cosa fare nelle prime 24 ore: triage, bump SemVer, rigenerazione SBOM e notifica ad ACN. Invito alla Track Cybersecurity su aiutiamoci.cloud.	Mezzo Busto Frontale con box finale riassuntivo e QR Code / Link al corso.

NOTA PER IL MONTAGGIO: Inserire nei passaggi di transizione tra un atto e l'altro un cartello pulito con badge testuale e colore tematico (Blu per Atto 1, Rosso/Ambra per Atto 2, Viola per Atto 3, Smeraldo per Atto 4, Slate per Atto 5).

[COPIONE TELEPROMPTER] [ATTO 1 & ATTO 2]

Dossier Video • Guida Teleprompter Parola per Parola

Durata stimata blocco: 4 min 30 sec
Inquadratura principale: Camera 1 (Mezzo Busto) + Grafica Timeline

3. ATTO 1: SMONTARE IL CLICKBAIT ("IL VIBE CODING FINISCE L'11 SETTEMBRE 2026?")

[TELEPROMPTER • STEFANO • PAROLA PER PAROLA]

«Negli ultimi mesi si è diffusa sui social e su YouTube una narrazione terrorista: "*Attenzione! Con l'entrata in vigore del Cyber Resilience Act europeo, il Vibe Coding è ufficialmente morto. Se usi Cursor, Claude Code o ChatGPT per creare applicazioni, dal prossimo anno rischi sanzioni fino a 15 milioni di euro*".

Facciamo subito chiarezza con i testi normativi alla mano: **questa affermazione è una colossale bufala da clickbait**.

Il Regolamento Europeo 2024/2847 — noto come **Cyber Resilience Act (CRA)** — non proibisce in nessun articolo l'utilizzo dell'intelligenza artificiale per scrivere codice. Non vieta i Large Language Model, non vieta l'autocompletamento neurale e non punisce chi programma in linguaggio naturale.

Non solo: il CRA **non si applica affatto** al software sviluppato per uso puramente personale, a progetti di ricerca amatoriale o a piattaforme SaaS cloud erogate come mero servizio senza componenti client installabili.

Ma allora perché tutti ne parlano con ansia? C'è un punto cruciale che la maggior parte di chi fa Vibe Coding sta ignorando completamente: **il CRA regola chiunque immetta sul mercato europeo "prodotti con elementi digitali"**.

Se costruisci un'applicazione desktop, un'app per smartphone Android o iOS, un agente software on-premise da installare sui server di un cliente o un plugin commerciale per un gestionale, **tu sei legalmente un fabbricante di software**. E alla legge europea non importa minimamente se il codice lo hai digitato tu a mano alle tre di notte o se lo ha scritto Claude in tre secondi. Alla legge interessa una sola cosa: **che tu sia responsabile e pienamente consapevole della sicurezza di ogni singola riga e libreria che stai consegnando a quel cliente**».

> ***NOTE REGIA:*** *Tono energico, rassicurante ma fermo. Al secondo capoverso far comparire a schermo l'estratto dell'Articolo 2 del Regolamento UE 2024/2847 con evidenziatore giallo su "prodotti con elementi digitali messi a disposizione sul mercato".*

4. ATTO 2: LE 2 VERE SCADENZE DEL CYBER RESILIENCE ACT (2026 VS 2027)

[TELEPROMPTER • STEFANO • PAROLA PER PAROLA]

«Molti sviluppatori fanno confusione tra le date di applicazione del regolamento. Nel calendario legislativo dell'Unione Europea ci sono **due scadenze distinte** che ogni professionista del software deve scolpirsi in testa:

1) Prima scadenza: 11 SETTEMBRE 2026 — Obbligo di Segnalazione Vulnerabilità Attive.
Tra meno di un anno e mezzo scatta l'obbligo formale per chiunque distribuisca software di notificare a **ENISA** (l'Agenzia Europea per la Cybersicurezza) e al **CSIRT Nazionale** (in Italia incardinato presso l'Agenzia per la Cybersicurezza Nazionale - ACN) qualsiasi vulnerabilità attivamente sfruttata nei propri prodotti, secondo una timeline serratissima: un *Early Warning* entro **24 ore**, una notifica tecnica completa entro **72 ore** e una relazione finale entro **14 giorni** dalla disponibilità della patch.

2) Seconda scadenza: 11 DICEMBRE 2027 — Piena Applicazione del CRA e Marcatura CE.
Dal dicembre 2027 il software commerciale immesso nell'Unione dovrà possedere i requisiti essenziali di sicurezza by-design, la marcatura CE, il fascicolo tecnico e la disponibilità obbligatoria della **SBOM (Software Bill of Materials)** in formato machine-readable per tutti i componenti integrati».

[TIMELINE NORMATIVA CRA • REGOLAMENTO UE 2024/2847]

NOVEMBRE 2024
Pubblicazione Gazzetta Ufficiale UE
Entrata in vigore formale del Regolamento (UE) 2024/2847. Avvio periodo transitorio di adeguamento.

11 SETTEMBRE 2026
Reporting Attivo Vulnerabilità (24h/72h)
Obbligo notifica a ENISA e CSIRT/ACN per ogni vulnerabilità zero-day sfruttata o incidente informatico grave.

GIUGNO 2027
Standard Armonizzati SBOM
Definizione schemi formali CycloneDX 1.5/SPDX per le dogane digitali e i contratti con la Pubblica Amministrazione.

11 DICEMBRE 2027
Piena Applicazione CRA & Marchio CE
Marcatura CE obbligatoria. Sanzioni fino a 15M euro o 2.5% del fatturato per chi distribuisce prodotti privi di tracciabilità.

[CRITICAL RISK] [ATTO 3 • SUPPLY CHAIN]

Dossier Video • L'Anello Debole dell'Ecosistema AI

Durata stimata blocco: 2 min 30 sec
Focus: Dipendenze Transitive, SemVer & La Domanda da 1 Milione

5. ATTO 3: IL VERO TALLONE D'ACHILLE DEL VIBE CODER (LA SOFTWARE SUPPLY CHAIN)

[TELEPROMPTER • STEFANO • PAROLA PER PAROLA]

«Se il problema non è l'AI che scrive codice, qual è allora il vero tallone d'Achille di chi fa Vibe Coding? È la **Software Supply Chain**, la catena di fornitura del software open source.

Guardate come lavora normalmente chi usa gli agenti AI: apre Cursor o Claude Code e dice: "*Creami una dashboard Next.js con autenticazione Supabase, esportazione report in PDF, grafici interattivi e sincronizzazione cloud*". L'agente AI esegue all'istante, ma per farlo aggiunge 40 librerie esterne nel file `package.json` o `requirements.txt`.

Quello che molti sviluppatori non calcolano è che ciascuna di quelle 40 librerie si porta dietro le proprie sotto-dipendenze transitive. Nel giro di cinque minuti, all'interno della cartella `node_modules` o del virtual environment finiscono **800 pacchetti open source** scritti da centinaia di autori sconosciuti in giro per il mondo.

E qui arriviamo alla **domanda da un milione di euro** che ogni auditor di sicurezza o responsabile acquisti di un'azienda strutturata vi farà:

> **"Se domattina la CISA americana o l'ACN italiana pubblica un bollettino di allerta su una vulnerabilità critica Zero-Day in una libreria open source, tu vieni a saperlo in 24 ore? E riesci a dire in 10 secondi esatti quali tuoi software e quali versioni installate dai tuoi clienti contengono quella specifica libreria vulnerabile?"**

Se la tua risposta è: "*Devo aprire 20 repository su GitHub, controllare riga per riga a mano e sperare che le versioni coincidano*", sei completamente fuori legge rispetto al Cyber Resilience Act e fuori mercato per qualsiasi cliente enterprise».

> ***NOTE REGIA:*** *Durante la lettura della "Domanda da 1 Milione di Euro", stringere su Camera 1 in primo piano con grafica in evidenza a tutto schermo. Tono calmo, professionale, senza gridare.*

6. CONFRONTO: VIBE CODING CIECO VS INGEGNERIA AI CONFORME CRA

[KO] VIBE CODING CIECO (NON CONFORME CRA)

Dipendenze Flottanti: Versioni indicate con il cappelletto ^ o tilde ~ nel package.json. Ogni installazione scarica versioni diverse non testate.
Nessuna Carta d'Identità Build: Il software ha sempre la versione `0.1.0` hardcodata per mesi, senza numero di compilazione né associazione univoca.
Git Caotico: Nessun tag crittografico, commit anonimi, impossibile ricostruire quale sorgente esatta ha generato l'eseguibile del cliente.
Nessuna Distinta Base (SBOM): Zero visibilità sulle librerie transitive; le vulnerabilità zero-day rimangono invisibili fino all'attacco.
Tempo di Risposta a Incidente: Giorni o settimane di ispezione manuale disperata (violazione termine 24h CSIRT/ACN).

[OK] INGEGNERIA AI CONFORME CRA (APPROCCIO PRO)

Lockfile & SemVer Rigido: Dipendenze bloccate bit-per-bit (`package-lock.json`) con versioni esatte e verificate crittograficamente.
BUILD_INFO.json Integrato: Ogni singola release include metadati automatici: versione, numero di build, commit Git, branch e data UTC.
Git Tag Annotati & Firmati: Ogni build di produzione corrisponde a un tag Git immutabile (es. `v1.0.1+build.20261102.1042`).
SBOM CycloneDX 1.5 Machine-Readable: Distinta base completa esportata in formato standard europeo con identificatori unici `purl`.
Radar Istantaneo Sub-Secondo: Comando CLI aziendale che interroga tutti i progetti in 50 millisecondi ed evidenzia librerie vulnerabili.

PRINCIPIO ARCHITETTURALE YAGNI APPLICATO ALLA SICUREZZA: Più librerie terze installi per pigrizia, più allarghi la superficie d'attacco e gli oneri legali del CRA. La prima linea di difesa dell'ingegnere AI è la **Standard Library First**: usare le API native della piattaforma anziché aggiungere micro-pacchetti per compiti banali.

[LIVE SCREENCAST] [ATTO 4 • GLI STRUMENTI]

Dossier Video • Dimostrazione Pratica a Schermo in 3 Step

Durata stimata blocco: 2 min 45 sec
Inquadratura principale: Screencast 1080p/4K a tutto schermo

7. ATTO 4: DIMOSTRAZIONE PRATICA A SCHERMO (COSA MOSTRARE IN 3 MINUTI)

[TELEPROMPTER • STEFANO • INTRODUZIONE SCREENCAST]

«Basta teoria. Passiamo allo schermo e vediamo come noi risolviamo tutto questo nei nostri progetti reali in esattamente tre passaggi che potete replicare oggi stesso nei vostri software».

> **PASSAGGIO A SCREENCAST: Taglio netto su schermo. Stefano apre VS Code su un repository reale di produzione e illustra i tre artefatti chiave della pipeline CRA.**

STEP A • IL FILE D'IDENTITÀ DELLA BUILD (BUILD_INFO.JSON)

Ogni prodotto software distribuito deve incorporare un descrittore univoco generato automaticamente durante il processo di build:

```
// Percorso: /public/BUILD_INFO.json oppure embedded nell'eseguibile client
{
  "appName": "Piattaforma-Lavoro-Condivisa",
  "version": "1.0.1",
  "buildNumber": 1042,
  "fullBuildId": "1.0.1+build.20261102.1042",
  "gitCommit": "9f8a2b3c4d5e",
  "gitBranch": "main",
  "builtAt": "2026-11-02T10:15:00Z",
  "craCompliance": {
    "regulation": "EU CRA 2024/2847",
    "sbomFormat": "CycloneDX-1.5",
    "securityContact": "security@mark2.cloud",
    "csirtReportingReady": true
  }
}
```

STEP B • LA DISTINTA BASE DIGITALE (SBOM.CDX.JSON CYCLONEDX 1.5)

La SBOM standard europea registra ogni pacchetto con il suo identificatore globale `purl` (Package URL), versione esatta e hash crittografico:

```
// Estratto da: /sbom.cdx.json (Standard CycloneDX 1.5 approvato da ENISA)
{
  "bomFormat": "CycloneDX",
  "specVersion": "1.5",
  "metadata": {
    "timestamp": "2026-11-02T10:15:00Z",
    "component": { "name": "piattaforma-condivisa", "version": "1.0.1", "type": "application" }
  },
  "components": [
    {
      "name": "next",
      "version": "15.5.23",
      "purl": "pkg:npm/next@15.5.23",
      "hashes": [{ "alg": "SHA-256", "content": "a7b8c9d0e1f2..." }]
    }
  ]
}
```

STEP C • IL RADAR AZIENDALE CVE ISTANTANEO (CLI SCANNER IN 50MS)

In caso di avviso di vulnerabilità CSIRT/ACN, lo script aziendale scansiona l'intero ecosistema di progetti in meno di un decimo di secondo:

```
$ npm run sbom:lookup -- next

[RADAR SUPPLY CHAIN CRA] Ricerca del pacchetto "next" su 19 repository aziendali...
-------------------------------------------------------------------------------
PROGETTO AZIENDALE           VERSIONE DICHIARATA    VERSIONE LOCKATA REALE    STATO
-------------------------------------------------------------------------------
Piattaforma Lavoro Condivisa  ^15.0.0               15.5.23                   [OK - ALLINEATO]
Gestionale Produzione         ^15.0.0               15.5.23                   [OK - ALLINEATO]
Sito Mark2gest                ^14.2.1               14.2.1                    [ATTENZIONE: CVE-2024-XXXX]
Bot Trading Dashboard         ^15.0.0               15.5.23                   [OK - ALLINEATO]
-------------------------------------------------------------------------------
[RISULTATO] 19 progetti scansionati in 48ms. Individuato 1 repository da aggiornare.
```

[24H / 72H PROTOCOL] [ATTO 5 • INCIDENT RESPONSE]

Dossier Video • Protocollo Operativo di Risposta alle Vulnerabilità

Durata stimata blocco: 2 min 00 sec
Inquadratura principale: Tabella Operativa + Chiusura Mezzo Busto

8. ATTO 5: IL PROTOCOLLO DI RISPOSTA ALLE VULNERABILITÀ ATTIVE (TIMELINE CSIRT / ACN)

[TELEPROMPTER • STEFANO • TIMELINE OPERATIVA]

«Cosa succede se domani mattina esce una vulnerabilità Zero-Day su una libreria che utilizziamo? Grazie alla nostra architettura non entriamo nel panico. Seguiamo esattamente il protocollo operativo previsto dall'Articolo 14 del Cyber Resilience Act».

Finestra Temporale	Azione Tecnica del Team Dev	Adempimento CRA (ENISA / CSIRT ACN)	Output Prodotto & Tool Utilizzato
ORA 00:00 [RILEVAZIONE]	Pubblicazione bollettino CVE o allerta zero-day da NVD / CSIRT / GitHub Security Advisory.	Nessuna notifica immediata: avvio della finestra temporale delle 24 ore per la valutazione.	Esecuzione `npm run sbom:lookup`. Lista progetti impattati identificata in <1 minuto.
ENTRO 24 ORE [EARLY WARNING]	Isolamento del componente o disattivazione della feature vulnerabile se esposta al pubblico.	**Early Warning obbligatorio:** invio notifica preliminare al portale unico ENISA / ACN con descrizione della vulnerabilità attiva.	Ticket di incidente interno registrato; conferma di ricezione con identificativo formale CSIRT.
ORE 24 - 48 [REMEDIATION]	Aggiornamento chirurgico della dipendenza con patch del vendor, oppure workaround di sicurezza interno.	Nessuna notifica: lavoro intensivo di testing e validazione per evitare regressioni operative.	Nuovo build con bump SemVer, nuovo `BUILD_INFO.json`, rigenerazione `sbom.cdx.json`, Git Tag.
ENTRO 72 ORE [NOTIFICA COMPLETA]	Deploy in produzione della nuova build corretta e notifica di rilascio inviata a tutti i clienti.	**Notifica Completa CRA:** invio ad ACN e clienti della valutazione di impatto, IoC e versione patchata.	Security Advisory pubblicata con nuovo hash SBOM; rilascio confermato sul portale CSIRT.
ENTRO 14 GIORNI [REPORT FINALE]	Revisione post-mortem del processo: verifica assenza di compromissioni e chiusura audit.	**Relazione Finale Formale:** archiviazione della segnalazione con prove di risoluzione definitiva.	Fascicolo tecnico aggiornato e archiviato nel Vault Obsidian aziendale per future verifiche.

9. CHIUSURA VIDEO & CALL TO ACTION (TELEPROMPTER STEFANO)

[TELEPROMPTER • STEFANO • CHIUSURA VIDEO]

«L'era del codice generato con l'intelligenza artificiale e poi buttato online senza sapere cosa contiene è finita. Chi programma con l'AI oggi deve essere **più ingegnere di prima, non meno**.

La differenza tra un dilettante che gioca con i prompt e un professionista che costruisce software per le imprese passa tutta da qui: dalla capacità di governare la supply chain, tracciare le build in modo deterministico e rispondere a qualsiasi audit normativo in pochi secondi.

Nella nostra **Track Formativa Cybersecurity & AI Defense** su `aiutiamoci.cloud` insegniamo esattamente questo: non solo a far generare codice agli agenti, ma a blindarlo, certificarlo e renderlo conforme alle normative europee più esigenti.

Tutti gli script che avete visto oggi a schermo — dal generatore di `BUILD_INFO.json` al convertitore CycloneDX fino al Radar delle dipendenze — sono disponibili per i nostri studenti all'interno della piattaforma. Se volete fare il salto di qualità definitivo, vi aspettiamo nei prossimi moduli. A presto!».

> ***INQUADRATURA FINALE:*** *Camera 1 frontale a figura intera o mezzo busto stretto. Far comparire in sovrimpressione finale il banner grafico con il dominio* `aiutiamoci.cloud` *e il titolo del corso: "Corso AI Pro • Track Cybersecurity & AI Defense".*

[APPENDICE DIDATTICA] [PROMPT RCCF] [STUDENT PACK]

Track Cybersecurity & AI Defense • Appendice Pratica per Studenti

Applicabile su: Cursor, Claude Code, Antigravity, VS Code Copilot
Standard Tecnico: RCCF Framework + YAGNI Defense

10. SYSTEM PROMPT RCCF: "CRA & SOFTWARE SUPPLY CHAIN DEFENSE"

Incolla questo prompt nelle istruzioni di sistema (es. `.cursorrules`, `CLAUDE.md` o configurazione dell'agente) per obbligare l'IA a rispettare i requisiti del Cyber Resilience Act e la disciplina della Supply Chain:

```
# ================================================================================
# SYSTEM PROMPT: EU CRA COMPLIANCE & SOFTWARE SUPPLY CHAIN GUARDRAILS
# ================================================================================

[RUOLO]
Sei un Senior Software Security Architect specializzato in DevSecOps, conformità normativa
europea (EU Cyber Resilience Act UE 2024/2847) e protezione della Software Supply Chain.

[CONTESTO]
Stai scrivendo codice per applicazioni commerciali soggette agli obblighi di sicurezza
by-design e rendicontazione delle vulnerabilità alle autorità europee (ENISA / CSIRT ACN).

[DIRETTIVE TASSATIVE DI SVILUPPO (COMPITO)]
1. STANDARD LIBRARY FIRST (REGOLA YAGNI SUPPLY CHAIN):
   È severamente vietato installare nuovi pacchetti npm o librerie terze se la funzionalità
   può essere realizzata con costrutti nativi del linguaggio o della piattaforma (es.
   crypto nativo per hash/UUID, fetch standard per HTTP, structuredClone per deep copy).
   Ogni nuova libreria aggiunge debito normativo e superficie d'attacco CRA.

2. DIPENDENZE CRITTOGRAFICAMENTE BLOCCATE:
   Non generare mai comandi npm install con versioni flottanti o indefinite. Tutte le
   dipendenze devono essere registrate con versione esatta e lockfile rigoroso.

3. CARTA D'IDENTITÀ DELLA BUILD (BUILD_INFO.json):
   Qualsiasi processo di build o packaging deve generare o aggiornare il file descrittore
   con versione SemVer reale, buildNumber progressivo e identificatore Git immutabile.

4. GENERICITÀ ZERO-DAY & ISOLAMENTO:
   Tutti gli input esterni devono essere validati all'ingresso tramite schemi tipizzati
   (Zod / Typebox). È vietato l'uso di eval(), deserializzazioni insicure o query non preparate.

[FORMATO DI OUTPUT RICHIESTO]
Ogni volta che proponi l'aggiunta di una libreria esterna:
- Giustifica esplicitamente perché la Standard Library nativa non è sufficiente.
- Fornisci il comando esatto con versione esatta da aggiungere a package.json.
- Indica l'impatto sulla distinta base (SBOM) del progetto.
```

11. CHECKLIST PRE-RILASCIO IN 5 PUNTI (IL "BOLLINO BLU" DEL SOFTWARE AI)

Punto di Controllo	Cosa Verificare Meccanicamente	Comando o Strumento di Test	Esito Atteso
1. Pulizia Dipendenze	Verificare che non vi siano librerie inutilizzate o pacchetti deprecated nel lockfile.	`npm audit --production`	[0 VULNERABILITÀ]
2. Generazione BUILD_INFO	Verificare la presenza di `BUILD_INFO.json` con commit Git e timestamp reale.	`cat public/BUILD_INFO.json`	[BUILD ID PRESENTE]
3. Esportazione SBOM	Generare la distinta base CycloneDX 1.5 in formato JSON con metadati completi.	`npm run sbom:generate`	[SBOM.CDX.JSON VALIDO]
4. Tag Git Crittografico	Apporre il tag Git corrispondente alla versione rilasciata al cliente.	`git tag -a v1.0.1 -m "Release"`	[TAG ALLINEATO]
5. Test Radar Ecosistema	Interrogare il Radar SBOM per confermare la corretta indicizzazione del pacchetto.	`npm run sbom:lookup -- <pkg>`	[RISPOSTA <100MS]

MASSIMA OPERATIVA PER I BUILDER AI: *"L'intelligenza artificiale moltiplica di 100 volte la velocità con cui puoi creare codice; una solida ingegneria della supply chain impedisce che quell'accelerazione ti schianti contro le responsabilità legali del mercato".*